

Policies and Procedures — Guided Notes ANSWER KEY

Unit 3.3.2 | CompTIA Network+ N10-009 Obj. 3.3 | N10-008 3.3

For instructor use / distribute after students complete the notes.

Question 1

An Acceptable Use Policy (AUP) defines what users _____ and _____ do with network resources. Why must users acknowledge the AUP in writing (or digitally) rather than simply being told about it?

Answer: May (are permitted to); may not (are prohibited from). Written acknowledgment creates a documented record that the user was informed of the rules — essential for disciplinary action or legal proceedings if the policy is violated.

Question 2

A data classification policy assigns sensitivity levels to data. List the four common classification levels from least to most sensitive and give a school network example of each.

Answer: Public (school calendar, public website), Internal (staff meeting notes, curriculum materials), Confidential (student grades, personnel records), Restricted/Top Secret (financial data, SSNs, legal documents).

Question 3

The principle of least privilege in access control means users receive only the permissions _____ for their role. A student account that can modify grades violates this principle. What is the process called when access rights are reviewed periodically to remove unnecessary permissions?

Answer: Necessary/required; access review (or permission audit / user access review).

Question 4

An onboarding procedure creates accounts and grants access when a user joins. An offboarding procedure _____ accounts and revokes access when a user leaves. What specific security risk does a delay in offboarding create?

Answer: Disables/deletes; a former employee or contractor retains valid credentials and can access systems, data, or the VPN after their authorized relationship with the organization has ended.

Question 5

A password policy typically mandates minimum _____, complexity requirements, and maximum _____ (how often it must be changed). Modern NIST guidance actually recommends against frequent forced password changes unless there is evidence of compromise. Why?

Answer: Length; age (expiration interval). Frequent forced changes cause users to choose predictable patterns (Password1! → Password2!) or write passwords down, reducing overall security rather than improving it.

Question 6

A data retention policy defines how long different types of data must be kept before it can be _____. Name one legal reason a school district might be required to retain student records for a specific period.

Answer: Destroyed/deleted; FERPA (Family Educational Rights and Privacy Act) requirements, state education records laws, or potential litigation hold requirements that mandate preserving records relevant to legal proceedings.

Question 7

An incident response policy defines the steps taken when a security breach occurs: _____, _____, eradication, recovery, and lessons learned. Why must the 'lessons learned' phase be documented and not skipped?

Answer: Preparation; identification (and containment). Without documentation, the same type of incident is likely to recur — lessons learned feed back into policy updates, control improvements, and staff training that prevent repeat breaches.

Question 8 — Real World Application

REAL WORLD: A school district is audited after a data breach exposes 3,000 student records. The auditors find: no AUP, no data classification policy, contractor accounts that were never deactivated, and no incident response plan. For each missing policy, describe the specific harm it allowed in this scenario.

Answer: No AUP — no documented rules means no enforceable standard of conduct; users had no guidance on handling sensitive data. No data classification — student records were not identified as confidential, so no special protections (encryption, access controls) were applied. Undeactivated contractor accounts — a former contractor's credentials were used to access the system; offboarding procedures would have prevented this. No incident response plan — the district had no predefined steps to contain the breach, notify affected families, or preserve evidence, extending the damage and liability.